# Application Security Policy

Security guild · POL-SEC-07 · Version 4.0 · Effective 15 August 2026

> Fictional sample document for testing a domain-specialist RAG. Rules are cited as, for example, "AS-06".

## 1. Authentication

**AS-01** Administrator and production access requires multi-factor authentication with a phishing-resistant factor (FIDO2 security key or passkey). SMS codes are not accepted for administrators.

**AS-02** Login endpoints allow at most 5 failed attempts per account per 15 minutes, then require a CAPTCHA and notify the account owner.

**AS-03** Sessions expire after 30 minutes of inactivity and 12 hours absolute. Session cookies are Secure, HttpOnly and SameSite=Lax or Strict.

**AS-04** JSON Web Tokens must be verified for signature, expiry, issuer and audience. The `alg: none` header and algorithm switching are rejected.

## 2. Web and API protection

**AS-05** CORS uses an explicit allow-list of origins. `Access-Control-Allow-Origin: *` with credentials is forbidden.

**AS-06** Web applications send a Content-Security-Policy without `unsafe-inline` for scripts, plus Strict-Transport-Security with max-age of at least one year.

**AS-07** File uploads are limited to 10 MB, checked by content type and magic bytes (not only the extension), stored outside the web root, and scanned for malware before use.

**AS-08** Webhooks and callbacks are authenticated with an HMAC signature over the raw body and a timestamp; receivers reject signatures older than 5 minutes and compare signatures in constant time.

## 3. Secrets and supply chain

**AS-09** Repositories run secret scanning as a pre-commit hook and in CI. A detected live secret is revoked within 1 hour.

**AS-10** Every build produces a software bill of materials (SBOM) and container images are signed. Unsigned images are blocked from production.

## 4. Logging and detection

**AS-11** Security events (logins, failed logins, permission changes, key creation, data exports) are sent to the SIEM within 60 seconds and kept for 1 year.

**AS-12** Logs never contain passwords, tokens, full card numbers or government ID numbers.

## 5. AI features

**AS-13** Text from documents, emails, tickets or web pages that is sent to a language model is treated as untrusted and is delimited. Model output is never executed and never sent to external recipients without human approval.

**AS-14** Language-model features are red-teamed for prompt injection before release and after every model change.